

Firmar, verificar y medir

Cincuenta y cinco minutos en clase; los minutos de cada ejercicio son un ritmo sugerido y el docente gestiona el tiempo, así que lo que no se cierre en el aula continúa como trabajo independiente. Las demostraciones firman y verifican en su navegador, con la misma criptografía de curva elíptica que usa un certificado real. Los comandos de OpenSSL y el ejercicio en Python están abajo, con botón de copiar.

Antes de empezar. No se evalúa que la firma verifique. Se evalúa que expliquen **qué garantiza exactamente una firma válida y qué no**. La pregunta del caso —cómo probar ante un juez que una operación la autorizó su titular— se responde con esa distinción, no con un comando.

¿En qué terminal? En Windows, los comandos de abajo van en **Git Bash** (viene con Git para Windows y trae OpenSSL y las órdenes head, tail y cat), **no en cmd ni en PowerShell**, donde no existen. En macOS o Linux, la Terminal normal. La alternativa en Python corre en cualquier terminal.

DEMOSTRACIÓN • 5 MINUTOS

Una firma está ligada al mensaje

Se genera una pareja de llaves, se firma el pagaré y se verifica. Después cambie un solo carácter del texto y verifique de nuevo: la firma deja de valer, sin tocar la firma misma. Eso es lo que significa «ligada al mensaje».

EL PAGARÉ

Pagaré 2026-0415 por 180.000.000

Cambie un carácter del pagaré después de firmar y pulse Verificar: verá el resultado pasar a inválido.

Panel interactivo • ábralo en el navegador para ejecutarlo

Qué son la llave privada y la llave pública, en una frase cada una

La llave privada firma, y no sale nunca de quien firma. **La llave pública** verifica, y se la puede dar a todo el mundo. Nadie puede producir una firma que verifique con una llave pública sin tener la privada correspondiente: por eso una firma válida prueba que quien firmó tenía esa llave privada. Guarde esa última frase entera, porque el ejercicio 3 la va a poner a prueba: prueba que **la llave firmó**, no que **una persona quiso firmar**.

Generar, firmar y verificar

Generen una pareja de llaves, firmen un documento, verifíquelo. Después cambien un solo carácter del documento y vuelvan a verificar. Documenten qué ocurre y por qué.

CON OPENSSSL • UNA PAREJA DE CURVA ELÍPTICA

```
# generar la pareja de llaves
openssl genpkey -algorithm EC -pkeyopt ec_paramgen_curve:P-256 -out ec.key
openssl pkey -in ec.key -pubout -out ec.pub

# firmar el documento y verificar la firma
openssl dgst -sha256 -sign ec.key -out doc.sig documento.pdf
openssl dgst -sha256 -verify ec.pub -signature doc.sig documento.pdf

# cambien un byte de documento.pdf y repitan la verificación:
# la última orden dirá "Verification Failure"
```

O EN PYTHON, CON ED25519, LA FIRMA MODERNA POR DEFECTO

```
# pip install cryptography
from cryptography.hazmat.primitives.asymmetric import ed25519
from cryptography.exceptions import InvalidSignature

privada = ed25519.Ed25519PrivateKey.generate()
publica = privada.public_key()

doc = b"Pagare 2026-0415 por 180.000.000"
firma = privada.sign(doc)

publica.verify(firma, doc) # correcto: no lanza nada
try:
    publica.verify(firma, b"Pagare 2026-0415 por 980.000.000") # un dígito distinto
except InvalidSignature:
    print("la firma no corresponde a este documento")
```

QUÉ SE ENTREGA DE ESTE EJERCICIO

- La firma verificando sobre el documento original, y fallando sobre el alterado.
- La explicación de por qué basta cambiar un carácter para que falle, ligándola con lo que aprendieron de las funciones de resumen en la sesión 3.

Medir la diferencia entre RSA y curva elíptica

Comparen tiempo de generación, tiempo de firma y tamaño de llave entre RSA y curva elíptica al mismo nivel de seguridad. Este panel lo mide en su navegador; lleven los números a una tabla.

BANCO DE PRUEBAS

FIRMAS A CRONOMETRAR

200

Panel interactivo · ábralo en el navegador para ejecutarlo

Por qué la comparación es justa a «128 bits»

RSA y las curvas elípticas resuelven problemas matemáticos distintos, así que sus tamaños de llave no se comparan directamente. Para igualar la dificultad —lo que costaría romperlos— hay tablas de equivalencia: **RSA-3072 equivale a curva P-256**, y ambos a unos 128 bits de seguridad simétrica. Comparar RSA-3072 con P-256 es comparar dos cerraduras igual de difíciles de forzar, y ver cuál pesa menos y se abre más rápido.

El resultado, que van a ver en los números: la curva genera la llave y firma mucho más rápido, y su llave es una fracción del tamaño. Por eso un teléfono firma con curva y no con RSA, y por eso importa para la aplicación del asociado.

LA MISMA MEDICIÓN CON OPENSRL, PARA CONTRASTAR

```
openssl speed rsa3072 ecdsap256
```

QUÉ SE ENTREGA DE ESTE EJERCICIO

- La tabla con las tres columnas —generar, firmar, tamaño— para los dos esquemas.
- Una frase sobre por qué esa diferencia importa para la aplicación móvil de Coopaburrá, que firma en el teléfono del asociado.

EJERCICIO 3 · 15 MINUTOS

Verificar con la llave equivocada

Aquí está el corazón del caso. Se firma un documento con la llave de **Ana** y se intenta verificar con la llave pública de **Beto**. Después se responde la pregunta que dejó mudo al comité.

DOS PERSONAS, DOS PAREJAS DE LLAVES

Autorizo la transferencia de mi cuenta

Panel interactivo · ábralo en el navegador para ejecutarlo

Qué garantiza la firma válida, y qué no — léalo antes de escribir el informe

Cuando la firma verifica con la llave pública de Ana, queda probado que **la llave privada de Ana** produjo esa firma sobre ese documento exacto. Eso es mucho: nadie sin esa llave pudo haberla hecho, y el documento no se tocó después.

Lo que **no** queda probado es que Ana, la persona, quisiera firmar. Si su llave estaba en un archivo que compartían once personas —H2 del caso— o en un teléfono que perdió, la firma es válida y aun así no dice que fue ella. La firma prueba **qué llave firmó**. Que esa llave sea de una persona, y solo de ella, es un problema distinto: es la custodia de la llave, y es lo que Coopaburrá no tiene.

Por eso el no repudio no lo da el algoritmo de firma por sí solo. Lo dan tres cosas juntas: una firma que verifica, una llave que pertenece a una sola persona y está bajo su control exclusivo, y un tercero que dé fe de ese vínculo. Las dos últimas son el tema de la sesión 5.

QUÉ SE ENTREGA DE ESTE EJERCICIO

- El resultado: verifica con la llave de Ana, falla con la de Beto.
- **La respuesta a la pregunta del caso:** qué quedaría todavía sin resolver aunque la firma de una operación verifique correctamente. Esa frase es el puente a la sesión del martes.
- Una línea sobre el hallazgo H2: con la llave de firma compartida por 142.000 personas, ¿qué prueba realmente una operación «firmada»?

REPASO • 5 MINUTOS

¿Qué servicio da, y cuál no?

Seis situaciones sobre firma digital. Elijan qué es lo que realmente está en juego.

1. Una firma verifica correctamente con la llave pública de Ana.

2. Se cambia un carácter del documento y la firma deja de verificar.

3. La llave privada de firma está en un archivo que comparten once personas.

4. Un teléfono firma cada operación en menos de un milisegundo, con una llave de 32 bytes.

5. Hace falta, además de la firma, que un tercero dé fe de que la llave es de esa persona.

6. Se firma un pagaré hoy que debe seguir siendo probatorio en 2039.

Qué se entrega y cómo se califica

Una página por equipo con la tabla del ejercicio 2 y, sobre todo, la respuesta del ejercicio 3.

- ☐ La firma del ejercicio 1 verificando y fallando, con la explicación del porqué.
- ☐ La tabla de tiempos y tamaños de RSA frente a curva elíptica.
- ☐ La respuesta central: qué queda sin resolver aunque la firma verifique.
- ☐ La conexión con H2: qué prueba una operación firmada con una llave que tienen 142.000 personas.
- ☐ Una frase sobre el artículo 28 de la Ley 527: qué significa que la firma esté «ligada al mensaje», ahora que lo vieron pasar en pantalla.

Regla de trabajo del módulo. Las llaves privadas que generen en el laboratorio son de práctica: no las reutilicen para nada real y bórrenlas al terminar. Una llave privada que pasó por un archivo temporal ya no sirve para firmar nada serio.